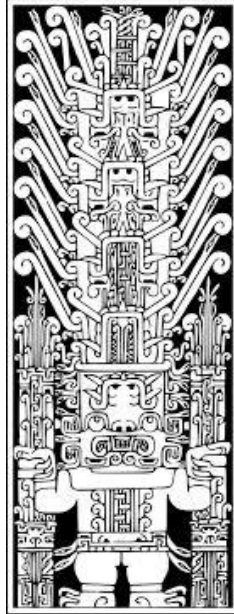


UNIVERSIDAD NACIONAL FEDERICO VILLARREAL

FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS

ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



TÍTULO:

**CLASIFICACIÓN DE ACTIVOS, GESTIÓN DE RIESGOS
Y CRITERIOS DE SEGURIDAD EN LAS EMPRESAS**

PRESENTADO POR:

Anampa Antayhua Alberto

DOCENTE:

VILLAFUERTE BARRETO, HERNAN OSWALDO

**ASIGNATURA
CIBERSEGURIDAD**

LIMA - PERÚ

2026

CLASIFICACIÓN DE ACTIVOS, GESTIÓN DE RIESGOS Y CRITERIOS DE SEGURIDAD EN LAS EMPRESAS

1. Introducción

La información es uno de los activos más valiosos de cualquier organización. Su pérdida, alteración o divulgación no autorizada puede generar impactos económicos, legales, operativos y reputacionales significativos. Por ello, la seguridad de la información no puede gestionarse de manera intuitiva: requiere un enfoque estructurado que permita identificar qué se protege, de qué se protege y con qué prioridad.

Este informe desarrolla tres pilares interrelacionados de la gestión de la seguridad de la información en las empresas: la clasificación de activos, la gestión de riesgos y los criterios utilizados para tomar decisiones de protección. Asimismo, se presentan los principales marcos y estándares internacionales que las organizaciones adoptan para estructurar estos procesos, con el objetivo de ofrecer una visión integral que sirva como base teórica y práctica para su aplicación en un contexto organizacional real.

2. Clasificación de Activos de Información

2.1 ¿Qué es un activo de información?

Un activo de información es cualquier recurso que tiene valor para la organización y que, por tanto, requiere algún nivel de protección. No se limita a datos digitales: incluye también hardware, software, personas, instalaciones y hasta la reputación e imagen corporativa.

2.2 Tipos de activos

- Activos de información: bases de datos, contratos, código fuente, propiedad intelectual, registros de clientes.
- Activos de software: sistemas operativos, aplicaciones, herramientas de desarrollo.
- Activos físicos: servidores, equipos de cómputo, dispositivos de red, medios de almacenamiento.
- Servicios: conectividad, energía eléctrica, servicios en la nube, climatización.
- Personas: conocimiento, experiencia y habilidades del personal clave.
- Intangibles: reputación, imagen de marca y confianza de los clientes.

2.3 Criterios de clasificación

La mayoría de las metodologías clasifican los activos evaluando el impacto de una eventual afectación sobre tres propiedades fundamentales:

- Confidencialidad: que la información solo sea accesible para quienes están autorizados.
- Integridad: que la información se mantenga exacta y completa, sin alteraciones no autorizadas.
- Disponibilidad: que la información esté accesible cuando se necesite.

A partir de la valoración de estas tres dimensiones (habitualmente en una escala de bajo, medio y alto) se obtiene un nivel de criticidad global para cada activo, el cual determina los controles de seguridad que le corresponden.

2.4 Niveles habituales de clasificación

Nivel	Descripción	Ejemplo
Público	Información que puede divulgarse sin restricción y no genera impacto negativo.	Folletos comerciales, notas de prensa
Interno	Uso exclusivo del personal de la organización. Su divulgación externa no es deseable pero el impacto es limitado.	Manuales internos, organigramas
Confidencial	Acceso restringido a un grupo definido. Su divulgación puede causar daño moderado a alto.	Datos de clientes, contratos, planes estratégicos
Restringido / Secreto	Máximo nivel de protección. Su divulgación puede causar daño grave o crítico.	Claves criptográficas, información financiera sensible, datos de salud

2.5 Inventario y propiedad de los activos

La clasificación solo es efectiva si se sostiene sobre un inventario de activos actualizado, donde cada activo tenga asignado un propietario responsable de definir su nivel de clasificación, autorizar accesos y revisar periódicamente su vigencia. Sin un inventario confiable, cualquier ejercicio de gestión de riesgos posterior carece de una base sólida.

3. Gestión de Riesgos

3.1 Conceptos básicos

- Amenaza: evento potencial que puede causar daño a un activo (malware, error humano, desastre natural).
- Vulnerabilidad: debilidad que puede ser explotada por una amenaza (software desactualizado, falta de cifrado).
- Riesgo: probabilidad de que una amenaza explote una vulnerabilidad, generando un impacto sobre un activo.
- Impacto: magnitud del daño que se produciría si el riesgo se materializa.

3.2 Proceso de gestión de riesgos

Aunque cada marco de referencia utiliza su propia terminología, el proceso de gestión de riesgos comparte una lógica común:

1. Identificación de activos, amenazas y vulnerabilidades.
2. Análisis del riesgo: estimación de probabilidad e impacto.
3. Evaluación del riesgo: comparación frente a los criterios de aceptación definidos por la organización.
4. Tratamiento del riesgo: selección e implementación de controles.
5. Monitoreo y revisión continua, dado que amenazas y activos cambian con el tiempo.
6. Comunicación y consulta con las partes interesadas durante todo el proceso.

3.3 Estrategias de tratamiento del riesgo

Estrategia	Descripción
------------	-------------

Evitar	Eliminar la actividad o condición que genera el riesgo (descontinuar un servicio inseguro).
Mitigar	Reducir la probabilidad o el impacto mediante controles (cifrado, copias de respaldo, autenticación multifactor).
Transferir	Trasladar parte del riesgo a un tercero (contratación de un seguro cibernético o de un proveedor especializado).
Aceptar	Asumir el riesgo de forma consciente cuando su nivel se encuentre entre los límites de tolerancia definidos por la organización.

3.4 Matriz de riesgo

Una herramienta muy utilizada para priorizar riesgos es la matriz de calor, que cruza la probabilidad de ocurrencia con el impacto potencial:

Probabilidad \ Impacto	Bajo	Medio	Alto
Alta	Medio	Alto	Crítico
Media	Bajo	Medio	Alto
Baja	Bajo	Bajo	Medio

Los riesgos ubicados en la zona crítica o alta suelen requerir tratamiento inmediato y aprobación de la alta dirección, mientras que los de nivel bajo pueden gestionarse mediante controles rutinarios o quedar registrados y aceptados formalmente.

4. Criterios Utilizados por las Empresas

4.1 Criterios de valoración de activos

Para asignar un valor a cada activo, las organizaciones suelen definir criterios objetivos y verificables, entre los que destacan:

- Valor económico de reposición o de mercado del activo.
- Impacto legal o regulatorio ante su pérdida o divulgación (protección de datos personales).
- Impacto en la continuidad operativa del negocio.
- Impacto reputacional frente a clientes, socios y el mercado.
- Dependencia de otros procesos o sistemas críticos respecto de ese activo.

4.2 Criterios de aceptación del riesgo

El nivel de riesgo que cada organización está dispuesta a tolerar varía según el sector, el tamaño y la cultura de cada organización. Generalmente se establecen mediante:

- Umbrales cuantitativos (pérdida económica máxima tolerable) o cualitativos (bajo, medio, alto).
- Políticas corporativas aprobadas por la alta dirección o el comité de riesgos.
- Requisitos normativos y contractuales aplicables (leyes de protección de datos, estándares del sector financiero, etc.).
- Análisis costo-beneficio: el costo del control no debería superar el valor del activo que protege.

4.3 Roles y responsabilidades

Rol	Responsabilidad
Propietario del activo (owner)	Define la clasificación, autoriza accesos y decide el tratamiento del riesgo asociado al activo.
Custodio del activo	Administra y protege el activo de forma operativa, siguiendo las directrices del propietario.
Responsable de seguridad	Diseña la estrategia de seguridad, coordina la gestión de riesgos y reporta a la alta dirección.
Comité de riesgos / Alta dirección	Aprueba el nivel de riesgo tolerable, los criterios de aceptación y los presupuestos de seguridad.
Usuarios finales	Cumplen las políticas de clasificación y manejo seguro de la información en su uso diario.

5. Principales Marcos de Referencia

Existen diversos estándares y metodologías internacionales que estructuran la clasificación de activos y la gestión de riesgos. A continuación se describen los más utilizados por las empresas.

5.1 ISO/IEC 27001 e ISO/IEC 27005

La norma ISO/IEC 27001 establece los requisitos para implementar un Sistema de Gestión de Seguridad de la Información (SGSI), dentro del cual la gestión de riesgos es un componente central. La norma ISO/IEC 27005 complementa a la anterior detallando específicamente el proceso de gestión de riesgos de seguridad de la información, incluyendo la identificación, análisis, evaluación y tratamiento del riesgo.

5.2 NIST CSF y NIST SP 800-30

El Marco de Ciberseguridad del NIST (Cybersecurity Framework) organiza la gestión de la ciberseguridad en cinco funciones: identificar, proteger, detectar, responder y recuperar. La guía NIST SP 800-30 ofrece una metodología detallada para la evaluación de riesgos, ampliamente utilizada tanto en el sector público como privado.

5.3 MAGERIT

MAGERIT es una metodología de análisis y gestión de riesgos desarrollada por la administración pública española. Es especialmente utilizada en organismos públicos y empresas de habla hispana, y se apoya en la herramienta PILAR para automatizar el análisis. Su enfoque es muy detallado en la valoración de activos según dimensiones de seguridad.

5.4 COBIT

COBIT (Control Objectives for Information and Related Technologies) es un marco de gobierno y gestión de TI desarrollado por ISACA. Aunque no está centrado exclusivamente en seguridad, incluye objetivos de control relacionados con la gestión de riesgos y la protección de activos de información dentro de una visión más amplia de gobierno corporativo de TI.

5.6 Cuadro comparativo

Marco	Enfoque principal	Uso típico
ISO/IEC 27001-27005	SGSI y gestión de riesgos de la información	Empresas de cualquier sector que buscan certificación

NIST CSF / SP 800-30	Funciones de ciberseguridad y evaluación de riesgos	Sector público y privado, infraestructuras críticas
MAGERIT	Análisis detallado de activos y riesgos	Administración pública y empresas hispanohablantes
COBIT	Gobierno y gestión de TI	Auditoría y gobierno corporativo de TI

6. Conclusiones

- La clasificación de activos es el punto de partida de cualquier estrategia de seguridad, ya que permite priorizar recursos y esfuerzos de protección según el valor real de cada activo para la organización.
- La gestión de riesgos no es un evento único sino un proceso continuo, que debe revisarse periódicamente ante cambios en el negocio, la tecnología y el panorama de amenazas.
- Los criterios de valoración y aceptación del riesgo deben ser definidos y aprobados por la alta dirección, alineados con los objetivos estratégicos y el marco legal aplicable a la organización.
- La adopción de marcos reconocidos como ISO/IEC 27001-27005, NIST o MAGERIT aporta estructura, comparabilidad y credibilidad frente a clientes, reguladores y auditores.